

CYBERSECURITY RISK ASSESSMENT REPORT

RetailNova Pty Ltd

Prepared for: Executive Leadership Team

Prepared by: Cybersecurity Analyst (Graduate), Internal Security Team

Date of Report: 12 Jul 2026

Classification: Confidential – Internal Use Only

Threat and Vulnerability Identification

Use this template to identify key assets, associated threats, potential vulnerabilities, and initial ideas for mitigation across RetailNova's environment.

Asset Name	Asset Description	Associated Threats	Potential Vulnerabilities	Mitigation Notes
Customer Data	Names, emails, phone numbers, addresses, purchase history, loyalty data stored across systems.	Data theft, third-party vendor compromise	Data shared with third parties without adequate oversight.	Encrypt data at rest and in transit, enforce strict data minimization and retention policies.
E-commerce website and Mobile Application	Customer-facing platform integrated with PayPal/Afterpay	External attacker (web app exploitation, payment fraud)	Custom-built software may have unpatched vulnerabilities	Conduct regular penetration testing and code reviews, implement a WAF, timely patching, enforce secure coding practices.
Cloud-connected POS systems	In-store payment processing	Malware and ransomware	Wide attack surface across many physical locations, potential lack of consistent patching.	Ensure consistent patch management across all stores, segment POS networks, maintain endpoint protection and monitoring.
Salesforce – CRM & SAP – ERP	Customer relationship and enterprise resource data	Insider misuse, credential compromise	Broad access to sensitive business/customer data	Apply RBAC with least-privilege principles, enable MFA for all accounts, log and monitor access, review permissions periodically.

AWS hosting environment	Cloud infrastructure hosting core systems	Misconfiguration, unauthorized access	Cloud misconfiguration, exposed storage/services	Conduct regular cloud configuration audits, enable logging and alerting, restrict public access to storage, apply least privilege to IAM roles.
Employee Endpoints (BYOD+VPN)	Personal devices accessing internal systems remotely	Phishing, credential theft	Personal devices outside security controls	Enforce MFA for VPN access, require MDM or minimum-security baseline for BYOD, use conditional access policies.
Third-party vendors (logistics, marketing, loyalty)	External partners with data access	Vendor compromise, supply chain risk	Limited vendor security oversight	Conduct vendor security due diligence before onboarding, include data protection clauses in contracts, limit vendor data access, require prompt breach reporting.
Microsoft Teams / Slack	Internal communications	Phishing, social engineering	Staff succeeding to phishing	Deliver regular phishing simulation and security awareness training, enable email/link scanning, enforce MFA on collaboration platform accounts.

Risk Criteria

The below explains what each item in the Risk Assessment means.

Criteria	Description
Risk Description	Detailed explanation of the scenario, what could go wrong, and why it matters.
Assets at Risk	The information, system, or service impacted (e.g. customer data, VDI environment).
Threat	Who or what could cause the risk (e.g. insider, cybercriminal, accident, malware). The action or event (e.g. data exfiltration, privilege misuse, physical theft).
Vulnerability	Weakness – the gap or condition that enables the threat (e.g. extended idle session, clipboard sharing).
Existing Controls	Current safeguards in place (e.g. MFA, logging, endpoint DLP).
Inherent Risk Rating	Risk level before any mitigations are applied.
Residual Risk Rating	Risk level after current controls are considered.
Likelihood	The probability of occurrence (e.g. Rare, Possible, Likely).
Consequence	Severity – level of damage if realised (e.g. Minor, Moderate, Major, Extreme).
Rating	The outcome of the risk likelihood and consequence evaluation.
Mitigations	Treatment plan – actions to reduce, transfer, avoid, or accept the risk.
Risk Owner	Person or role accountable for managing the risk.

Risk Assessment

This assessment covers three risks, selected because each is grounded in a real historical incident experienced by RetailNova, giving a factual basis for the likelihood ratings assigned.

Risk 1: Phishing Attack Leading to Credential Compromise

Risk Details			
Risk ID	RISK-001	Date Identified	12 Jul 2026
Risk Title	Phishing Attack Leading to Credential Compromise	Review Date	12 Jan 2027
Risk Identification			
Risk Description	A phishing campaign could target RetailNova staff, particularly customer-facing teams such as customer service or finance, tricking them into revealing login credentials for internal systems (e.g. Salesforce CRM, Microsoft Teams/Slack, or VPN access). Compromised credentials could allow an attacker to access customer data, internal communications, or pivot further into the network. This risk is grounded in a 2023 incident in which a phishing attack targeting customer service representatives resulted in credential compromise.		
Assets at Risk	Customer data held in Salesforce CRM, internal system credentials, Microsoft Teams/Slack accounts, and potentially broader network access gained via compromised credentials.		
Threat	External cybercriminal conducting a phishing or social engineering campaign to harvest employee credentials.		
Vulnerability	Insufficient email filtering and anti-phishing controls, limited staff awareness of phishing indicators, lack of MFA enforcement across all accounts.		
Existing Controls	Basic security awareness training for staff, firewalls and antivirus software, forced password resets following the 2023 incident.		
Inherent Risk Analysis			
Likelihood		Consequence	Inherent Risk Rating
Likely (4)		Major (4)	HIGH
Residual Risk Analysis			
Likelihood		Consequence	Residual Risk Rating
Possible (3)		Moderate (3)	MEDIUM
Risk Treatment			
Mitigations	Enforce MFA on all accounts, particularly customer-facing systems, conduct regular phishing simulation exercises, deploy advanced email filtering and attachment sandboxing, implement conditional access policies to restrict risky logins.		
Risk Monitoring and Review			

Monitoring Approach	Reviewed quarterly by the IT Security team. Phishing simulation results tracked monthly, and MFA enforcement coverage audited each quarter.
Risk Owner	IT Security Manager / CISO

Risk 2: Ransomware Attempt Targeting Corporate Endpoints

Risk Details			
Risk ID	RISK-002	Date Identified	12 Jul 2026
Risk Title	Ransomware Attempt Targeting Corporate Endpoints	Review Date	12 Jan 2027
Risk Identification			
Risk Description	Ransomware could infect corporate endpoints, including staff laptops and cloud-connected POS systems, causing operational disruption and potential data loss. This risk is grounded in a 2024 incident where a ransomware attempt was thwarted by endpoint protection, though it still caused two hours of downtime.		
Assets at Risk	Employee endpoints, cloud-connected POS systems across 85 stores, and potentially Salesforce/SAP systems if lateral movement occurs.		
Threat	Cybercriminal or malware deploying ransomware via phishing, a malicious attachment, or a vulnerable endpoint.		
Vulnerability	Endpoints across BYOD devices and store POS systems may lack consistent patching, potential gaps in network segmentation between POS systems and the corporate network.		
Existing Controls	Endpoint protection and antivirus software, which successfully contained the 2024 ransomware attempt, firewalls, basic staff awareness training.		
Inherent Risk Analysis			
Likelihood		Consequence	Inherent Risk Rating
Possible (3)		Major (4)	HIGH
Residual Risk Analysis			
Likelihood		Consequence	Residual Risk Rating
Possible (3)		Minor (2)	MEDIUM
Risk Treatment			
Mitigations	Extend Endpoint Detection and Response (EDR) coverage to all POS terminals, segment POS networks from the corporate/BYOD network, maintain immutable or offline backups, conduct regular ransomware tabletop exercises.		
Risk Monitoring and Review			

Monitoring Approach	Continuous EDR alert monitoring. Quarterly patch compliance audits across all store locations, and an annual ransomware simulation exercise.
Risk Owner	IT Infrastructure Manager

Risk 3: Data Exposure via Third-Party Marketing Vendor

Risk Details			
Risk ID	RISK-003	Date Identified	12 Jul 2026
Risk Title	Data Exposure via Third-Party Marketing Vendor	Review Date	12 Jan 2027
Risk Identification			
Risk Description	Customer data shared with third-party vendors across logistics, marketing, and loyalty programs could be exposed due to inadequate vendor security controls. This risk is grounded in a 2025 incident in which a data leak from a third-party marketing vendor exposed the email addresses of 5,000 customers.		
Assets at Risk	Customer PII, including email addresses and any other data shared with third-party vendors, along with the company's reputation.		
Threat	Third-party vendor security failure, whether accidental exposure or vendor-side compromise, leading to unauthorised disclosure of customer data.		
Vulnerability	Limited oversight and security due diligence over third-party vendors, no enforced data protection requirements or regular audits of vendor security posture.		
Existing Controls	Basic internal security awareness training only. No formal vendor risk management program currently exists, which is a significant gap.		
Inherent Risk Analysis			
Likelihood		Consequence	Inherent Risk Rating
Likely (4)		Moderate (3)	HIGH
Residual Risk Analysis			
Likelihood		Consequence	Residual Risk Rating
Likely (4)		Moderate (3)	HIGH
Risk Treatment			
Mitigations	Implement a formal third-party vendor risk management program, including security due diligence prior to onboarding, add contractual data protection and breach notification clauses, limit data shared with vendors to the minimum necessary, conduct periodic vendor security audits, encrypt data shared with vendors.		
Risk Monitoring and Review			

Monitoring Approach	Annual vendor security reviews. Security clauses verified at each contract renewal, with vendor incident reporting SLAs tracked on an ongoing basis.
Risk Owner	Data Protection Officer / Vendor Risk Manager

Note: unlike Risk 1 and Risk 2, the residual rating for Risk 3 remains HIGH, unchanged from its inherent rating. This reflects that no vendor-specific mitigating control currently exists for this vulnerability, an important finding that should be escalated to senior management.

Risk Escalation Email

As Risk 3 (RISK-003: Data Exposure via Third-Party Marketing Vendor) retains a HIGH residual rating with no effective mitigating control currently in place, this risk is escalated to senior management below, in line with the Risk Prioritisation Matrix guidance that HIGH-rated risks must be treated with priority and escalated.

To	Chief Information Security Officer, Head of IT Security
Cc	Legal Counsel, Head of Procurement
Bcc	Internal Audit
Subject	Escalation – High Residual Risk: Third-Party Vendor Data Exposure (RISK-003)

Hi team,

I'm writing to escalate RISK-003 (Data Exposure via Third-Party Marketing Vendor), identified during the current risk assessment cycle. This risk currently carries a HIGH residual rating, unchanged from its inherent rating, as no vendor-specific security control is currently in place to mitigate it. It is grounded in the 2025 incident in which a third-party marketing vendor exposed the email addresses of 5,000 customers.

Given RetailNova's reliance on multiple third parties across logistics, marketing, and loyalty programs, this gap presents an ongoing risk of further data exposure. I recommend the organisation prioritise establishing a formal vendor risk management program, including security due diligence, contractual data protection clauses, and periodic vendor audits, as outlined in the Risk Treatment section of the attached risk assessment.

Please let me know a suitable time to discuss next steps and resourcing for this initiative.

Kind regards, Cybersecurity Analyst (Graduate), Internal Security Team

Cybersecurity Risk Prioritisation Matrix

Understanding the Likelihood Rating

The table below provides the categories and ratings for likelihood:

Likelihood Ratings	Description	Criteria
Rare (1)	Exceptional circumstances only	May occur only in very unusual situations
Unlikely (2)	Possible, but not expected	Could happen but not typical, requires specific conditions (e.g. targeted phishing bypassing all filters).
Possible (3)	Might occur at some point	Has occurred in similar organisations, realistic but not frequent (e.g. ransomware attempt on enterprise endpoint).
Likely (4)	Will probably occur in most circumstances	Expected to happen periodically (e.g. phishing emails, credential stuffing attempts).
Almost Certain (5)	Expected to occur frequently	Has occurred multiple times, highly predictable (e.g. malware probes, daily scanning activity).

Understanding the Consequence Ratings Table

The table below provides the categories and ratings for impacts:

Consequence Rating	Description	Criteria
Insignificant (1)	Negligible impact	No compromise of sensitive data, no disruption, minimal financial or reputational impact.
Minor (2)	Small impact	Limited operational disruption, minimal data exposure (non-sensitive data), easily contained.
Moderate (3)	Noticeable impact	Partial service disruption, limited sensitive data exposure, moderate cost or compliance breach.
Major (4)	Severe impact	Significant outage of critical systems, large-scale sensitive data breach, regulatory non-compliance with penalties.
Extreme (5)	Catastrophic impact	Extended enterprise-wide outage, compromise of PROTECTED/SECRET data, severe financial/reputational damage, possible criminal or regulatory prosecution.

The 5x5 Risk Matrix

Use this 5x5 risk matrix to evaluate and prioritise cybersecurity risks. For each identified risk, assess its likelihood (1 = Rare, 5 = Almost Certain) and impact (1 = Insignificant, 5 = Extreme). Plot the risk in the matrix and use the result to guide mitigation priorities.

Risk Levels

Likelihood ↓ Impact →	Insignificant (1)	Minor (2)	Moderate (3)	Major (4)	Extreme (5)
5 – Almost Certain	MEDIUM	HIGH	HIGH	EXTREME	EXTREME
4 – Likely	MEDIUM	MEDIUM	HIGH	HIGH	EXTREME
3 – Possible	LOW	MEDIUM	MEDIUM	HIGH	HIGH
2 – Unlikely	LOW	LOW	MEDIUM	MEDIUM	HIGH
1 – Rare	LOW	LOW	LOW	MEDIUM	MEDIUM

- **Low** – Acceptable, manage by routine controls and monitoring.
- **Medium** – Requires management attention, additional controls may be needed.
- **High** – Significant, must be treated with priority, monitored closely, and escalated to senior management.
- **Extreme** – Unacceptable, immediate executive-level attention and remediation required.

Tips for Completing the Matrix

- Start by identifying the risk scenario (e.g. data breach, system outage). - Assign a likelihood score based on how often this type of risk occurs. - Assign an impact score based on potential damage to operations, reputation, or finances. - Use the matrix to prioritise: risks in the top-right corner (high likelihood and impact) need urgent attention.